

الأشياء / IoT Security :Lecture 9-10 Treasure

أمن إنترنت

تحليل هيكل المحاضرة / Lecture Structure

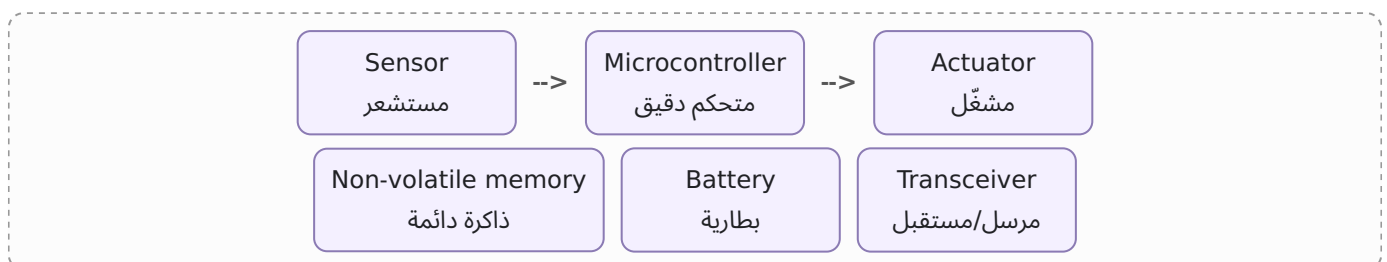
المحاضرة تتكون من 28 شريحة، ومحورها هو أمن **IoT / Internet of Things** من مكونات الجهاز حتى أمن البوابة والسحابة.

1. **IoT-enabled things** / الأشياء الممكنة بإنترنت الأشياء: مكونات الجهاز.
2. **IoT and Cloud Context** / سياق إنترنت الأشياء والسحابة: Edge, Fog, Core, Cloud.
3. **IoT Security** / أمن إنترنت الأشياء: البوابات، الأجهزة المقيدة وغير المقيدة، ومنطقة الأمان.
4. **Unique Characteristics** / الخصائص الفريدة التي تجعل أمن IoT صعباً.
5. **IoT Security Objectives** / أهداف أمن IoT حسب NISTIR 8200 كما وردت في السلايدات.
6. **Tamper Resistance and Detection** / مقاومة وكشف العبث.
7. **Gateway Security** / أمن البوابة.
8. **IoT Security Environment** / بيئة أمن IoT عبر Edge/Fog/Core/Cloud.
9. **MiniSec + TinyOS** / وحدة أمن مفتوحة المصدر وخوارزميات التشفير.

(1) أهم المصطلحات / Key Terms

المعنى المختصر للحفظ	المصطلح / English term
أجهزة متصلة بالشبكة تجمع بيانات أو تنفذ أفعلاً عبر حساسات ومشغلات.	IoT / Internet of Things / إنترنت الأشياء
يجمع بيانات من البيئة مثل حرارة، حركة، ضغط.	Sensor / مستشعر
ينفذ فعلاً فيزيائياً مثل فتح/إغلاق أو تشغيل محرك.	Actuator / مشغل
العقل الصغير داخل جهاز IoT لمعالجة البيانات والتحكم.	Microcontroller / متحكم دقيق
تحتفظ بالبيانات حتى بعد انقطاع الطاقة.	Non-volatile memory / ذاكرة غير متطايرة
واجهة الاتصال اللاسلكي أو الشبكي للإرسال والاستقبال.	Transceiver / مرسل ومستقبل
جهاز بذاكرة/معالجة/طاقة محدودة وغالباً أمنه ضعيف أو معدوم.	Constrained device / جهاز مقيد الموارد
جهاز لديه قدرة موارد أكبر وقد يدعم وظائف أمنية.	Unconstrained device / جهاز غير مقيد
عنصر وسيط مهم يربط أجهزة IoT بالأنظمة المركزية ويضيف أمن مثل TLS/IPsec.	Gateway / بوابة
تعديل غير مصرح به يغيّر وظيفة النظام ويضعف أمانه.	Tampering / العبث
خاصية حماية سلبية تجعل الهجوم الفيزيائي صعباً.	Tamper resistant / مقاوم للعبث
تقنيات تجعل النظام يعرف أن هناك وصولاً فيزيائياً غير مرغوب.	Tamper detection / كشف العبث

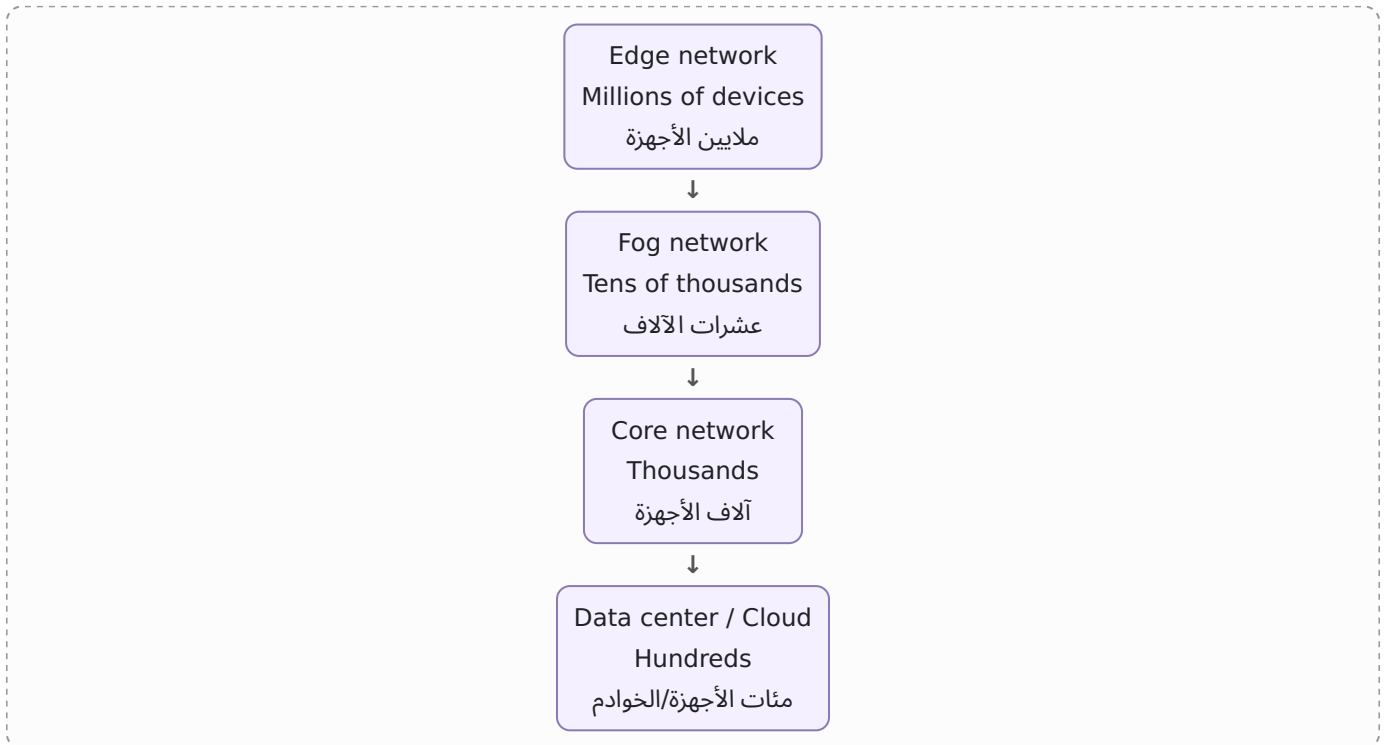
(2) مكونات جهاز IoT / Components of IoT-Enabled Things



فكرة شكل السلايد: جهاز IoT يحتوي Sensor + Actuator + Microcontroller + Memory + Battery + Transceiver.

احفظها كسلسلة: الجهاز يشعّر بالبيئة عبر **Sensor**، يعالج عبر **Microcontroller**، يتواصل عبر **Transceiver**، يخزن في **Non-volatile memory**، يعمل بالطاقة عبر **Battery**، ويؤثر في البيئة عبر **Actuator**.

(3) سياق IoT والسحابة / IoT and Cloud Context



المستوى / Level	وظيفته في المحاضرة	نقطة امتحانية
Edge / الحافة	شبكة أجهزة IoT عند طرف شبكة المؤسسة، تتكون من Sensors وربما Actuators.	الأقرب للبيئة الفيزيائية والأكبر عدداً.
Fog / الضباب	يحوّل تدفقات البيانات إلى معلومات مناسبة للتخزين والمعالجة الأعلى.	عمليات /Fog: Evaluation, Formatting, Expanding, decoding, Reduction, Assessment.
Core / القلب	يربط شبكات Fog الموزعة جغرافياً ويوفر الوصول لشبكات أخرى خارج المؤسسة.	طبقة ربط وتجميع بين Fog و Cloud.
Cloud / Data center / السحابة/مركز البيانات	يوفر التخزين والمعالجة للكمية الضخمة من البيانات القادمة من أجهزة IoT.	مكان المعالجة والتخزين المركزي للبيانات المجمعة.

(4) أمن IoT العام / General IoT Security

- **IoT security** / أمن إنترنت الأشياء هو من أكثر مجالات أمن الشبكات تعقيداً وأقل نضجاً.
- **Gateways** / البوابات غالباً تنفذ وظائف أمنية مثل TLS و IPsec.
- البوابة تؤمّن الاتصال بين **Gateway** والأنظمة المركزية مثل **Application platforms** و **Management platforms**.
- الأجهزة المقيدة أو غير المقيدة المتصلة بالبوابة قد تكون خارج منطقة الأمان بين البوابة والأنظمة المركزية.

نوع الجهاز	المعنى	الأثر الأمني
Unconstrained devices / أجهزة غير مقيدة	قد تملك موارد كافية وقد تطبق بعض وظائف الأمان.	إذا دعمت الأمان يمكنها الاتصال مباشرة بالمركز ودعم وظائف أمنية.
Constrained devices / أجهزة مقيدة	مواردها محدودة جداً.	غالباً لديها أمن محدود أو معدوم، وإذا لم تتصل ببوابة فلا يوجد اتصال آمن مع الأجهزة المركزية.

فكرة شكل IoT security

A = Application / Management / Storage platform - منصة تطبيق/إدارة/تخزين

G = Gateway / بوابة

U = Unconstrained device / جهاز غير مقيد

C = Constrained device / جهاز مقيد

التظليل في الشكل يعني أن العنصر يتضمن ميزات أمنية.

5) الخصائص الفريدة التي تصعب أمن IoT / Unique Characteristics

#	Characteristic / الخاصية	الشرح الامتحاني المختصر
1	Very large attack surfaces / سطح هجوم واسع جداً	نقاط ضعف كثيرة وأنواع بيانات كثيرة قد تتعرض للاختراق.
2	Limited device resources / موارد محدودة	أجهزة IoT غالباً محدودة الذاكرة والمعالجة والطاقة.
3	Complex ecosystem / نظام بيئي معقد	عدد كبير من الأجهزة مع اتصالات واعتماديات بينها ومع السحابة.
4	Fragmentation of standards and regulations / تشتت المعايير والتنظيمات	قلة معايير أمن IoT وأفضل الممارسات تجعل الإرشاد الأمني غير مكتمل.
5	Widespread deployment / انتشار واسع	انتشار سريع في بيئات تجارية وبنى تحتية حرجية بدون تقييم مخاطر كافٍ.
6	Physical Security / الأمن الفيزيائي	لأن أجهزة IoT تتفاعل مع البيئة الفيزيائية، التهديد الأمني قد يصبح تهديد سلامة.
7	Security integration / تكامل الأمان	بروتوكولات كثيرة مثل Zigbee, Bluetooth, LTE, Wi-Fi ومخططات مصادقة مختلفة تجعل التوافق والاتساق صعبين.
8	Low cost / انخفاض التكلفة	الشركات قد تقلل خصائص الأمان لتخفيض التكلفة، والذين قد يقبلون ذلك.
9	Lack of expertise / نقص الخبرة	عدد محدود من الأشخاص ذوي تدريب وخبرة مناسبة في أمن IoT.
10	Security update / التحديث الأمني	المستخدم قد لا يملك طريقة للترقية، أو لا يعرف متى وكيف يطبق Patch.
11	Insecure programming / برمجة غير آمنة	المطورون قد يركزون على الوظيفة وسهولة الاستخدام أكثر من الأمان.
12	Unclear liabilities / مسؤوليات غير واضحة	سلاسل توريد وتفاعل مكونات كثيرة تجعل تحديد المسؤولية بعد الحادث صعباً.

6) أهداف أمن IoT / IoT Security Objectives

حسب السلايدات، NISTIR 8200 يذكر الأهداف التالية:

#	Objective / الهدف	أهم التفاصيل للحفظ
1	Restricting logical access to the IoT network تقييد الوصول المنطقي لشبكة IoT	استخدام بوابات أحادية الاتجاه، جدران نارية لمنع المرور المباشر بين Corporate و IoT، آليات وبيانات اعتماد منفصلة، وطوبولوجيا متعددة الطبقات حيث تكون الاتصالات الحرجة في الطبقة الأكثر أماناً.
2	Restricting physical access تقييد الوصول الفيزيائي	استخدام ضوابط فيزيائية مثل Locks, Card readers, Guards.
3	Protecting individual IoT components from exploitation حماية كل مكون من الاستغلال	تطبيق Patches بعد اختبارها، تعطيل المنافذ والخدمات غير المستخدمة، أقل صلاحيات، Audit trails, Antivirus و File integrity حيث يمكن.
4	Preventing unauthorized modification of data منع التعديل غير المصرح للبيانات	حماية البيانات أثناء النقل in transit وعند التخزين at rest .
5		

الكشف المبكر لكسر سلسلة الهجوم قبل تحقيق هدف المهاجم، مع كشف فشل مكونات IoT، عدم توفر الخدمات، ونفاذ الموارد.	Detecting security events and incidents كشف الأحداث والحوادث الأمنية	
تصميم المكونات الحرجة مع بديل احتياطي، وعند الفشل يجب ألا تولد حركة غير ضرورية أو تسبب مشكلة أخرى.	Maintaining functionality during adverse conditions الحفاظ على العمل أثناء الظروف السيئة	7
الحوادث حتمية، لذلك وجود Incident Response Plan ضروري.	Restoring the system after an incident استعادة النظام بعد الحادث	8

ملاحظة من السلايدات: الترقيم ينتقل من 5 إلى 7، ولا يظهر هدف رقم 6 في الملف؛ لذلك لم تتم إضافة هدف غير موجود.

7) مقاومة وكشف العبث / Tamper Resistance and Detection

في IoT توجد شركات تصنيع كثيرة وسلاسل توريد متعددة، وكثير من الأجهزة تنشر في أماكن يصعب تأمينها فيزيائياً؛ لذلك تظهر أهمية **Tamper resistance** و **Tamper detection**.

تعريف المحاضرة	Concept / المفهوم
تعديل غير مصرح به يغيّر الوظيفة المقصودة للنظام أو الجهاز بطريقة تضعف الأمان.	Tampering / العبث
خاصية في المكوّن توفر حماية سلبية ضد الهجوم.	Tamper resistant / مقاوم للعبث
تقنيات تجعل النظام العام على علم بوجود وصول فيزيائي غير مرغوب.	Tamper detection / كشف العبث

أ) Tamper resistance / مقاومة العبث

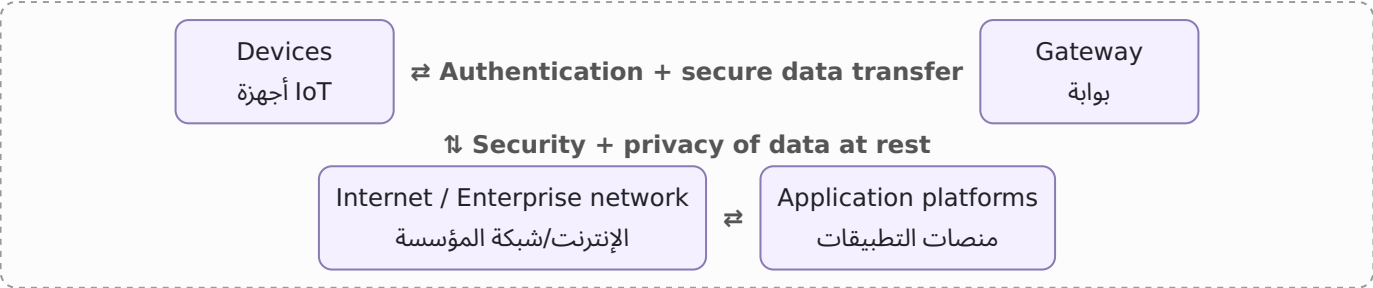
- الطريقة الشائعة: استخدام مواد بناء فيزيائية متخصصة تجعل العبث بالعقدة صعباً.
- أمثلة: **Hardened steel enclosures** / حاويات فولاذية مقواة، **Locks** / أقفال، **Security screws** / مسامير أمنية.

ب) Tamper detection / كشف العبث

الآلية / Mechanism	ماذا تكشف؟
Switches / مفاتيح	مثل Mercury switches, Magnetic switches, Pressure contacts؛ تكشف فتح الجهاز أو اختراق حد أمني أو حركة الجهاز.
Sensors / حساسات	حساسات حرارة وإشعاع تكشف تغير البيئة؛ حساسات جهد و طاقة تكشف الهجمات الكهربائية.
Circuitry / دوائر حماية	لف المكونات بدوائر مرنة أو أسلاك مقاومة أو ألياف بصرية لكشف الثقب أو القطع.

8) أمن البوابة / Gateway Security

Gateway / البوابة عنصر أساسي في أمن نشر IoT لأنها تربط الأجهزة بالتطبيقات وتوفر المصادقة وحماية البيانات.



فكرة شكل Gateway Security: اتصال آمن ومصادقة بين الأجهزة والبوابة، وبين البوابة ومنصات التطبيقات.

#	Common Requirements and Capabilities of Gateway	المعنى المختصر
1	Support identification of each access	تحديد كل عملية وصول إلى الأجهزة المتصلة.

مصادقة بين البوابة والأجهزة.	Support authentication with devices	2
مصادقة متبادلة مع التطبيقات.	Support mutual authentication with applications	3
حماية البيانات المخزنة في الأجهزة/البوابة والمنقولة بين الأجهزة والبوابة والتطبيق.	Support security of stored/transferred data	4
حماية الخصوصية للأجهزة والبوابة.	Support privacy mechanisms	5
تشخيص وإصلاح ذاتي وصيانة عن بعد.	Support self-diagnosis/self-repair/remote maintenance	6
دعم تحديث البرمجيات.	Support software update	7
دعم التهيئة التلقائية أو التهيئة بواسطة التطبيقات.	Support auto configuration	8

9) بيئة أمن IoT / The IoT Security Environment

الاسلايد يوضح قدرات أمنية رئيسية عبر أربعة مستويات: **Data center/cloud**, **Core network**, **Fog network**, **Edge network**.

Edge network أجهزة كثيرة وحساسات ومخاطر فيزيائية عالية.	Fog network تحويل ومعالجة أولية وتجميع بيانات.	Core network ربط الشبكات وتوجيهها.	Data center / Cloud تخزين ومعالجة مركزية.
---	--	--	---

الفكرة الامتحانية	القدرة الأمنية / Security capability
تحديد من يستطيع الوصول وماذا يستطيع فعله عبر مستويات IoT.	User authentication and access control / مصادقة المستخدم والتحكم بالوصول
مهم جداً في الطبقات التي تحتوي أجهزة مادية منتشرة، خاصة Edge/Fog/Core.	Tamper resistance and detection / مقاومة وكشف العبث
حماية البيانات أثناء النقل والتخزين عبر المنظومة.	Data protection and confidentiality / حماية وسرية البيانات
حماية الاتصالات والبروتوكولات بين مستويات IoT خاصة عبر الشبكات والوابات والسحابة.	Internet protocol and network security / أمن بروتوكولات الإنترنت والشبكة

10) TinyOS / Open-source IoT Security Module و MiniSec

العنصر	النقطة الأساسية
MiniSec / ميني سيك	وحدة أمن مفتوحة المصدر جزء من نظام TinyOS .
TinyOS / نظام تشغيل TinyOS	مصمم للأنظمة المضمنة الصغيرة ذات قيود الذاكرة والمعالجة والاستجابة للطاقة.
الاستخدام الرئيسي	شبكات الحساسات اللاسلكية، وأصبح نظاماً فعلياً شائعاً لها.
هدف MiniSec	وحدة على مستوى الرابط Link-level module توفر أماناً عالياً مع استهلاك طاقة وذاكرة منخفضين.

متطلبات MiniSec / MiniSec Requirements

#	Requirement / المتطلب	معناه للحفظ
1	Data authentication / مصادقة البيانات	يتأكد المستقبل أن الرسالة من عقدة شرعية تشاركها مفتاحاً سرياً ولم تتغير أثناء النقل.
2	Confidentiality / السرية	متطلب أساسي لأي نظام اتصالات آمن.
3	Replay protection / الحماية من إعادة الإرسال	يمنع المهاجم من تسجيل حزمة وإعادة تشغيلها لاحقاً بنجاح.
4	Freshness / الحداثة	تمكين المستقبل من معرفة ترتيب جزئي للرسائل المستقبلية دون وقت مرجعي محلي.
5	Low energy overhead / عبء طاقة منخفض	الأمن يجب ألا يستهلك طاقة كثيرة.
6	Resilient to lost messages / مقاومة لفقد الرسائل	يبقى يعمل حتى عند ضياع بعض الرسائل.

(11) خوارزميات التشفير / Cryptographic Algorithms

الخوارزمية / Algorithm	النقاط المهمة
Skipjack / سكيب جاك	من الخوارزميات الرئيسية في MiniSec؛ طورتها NSA في التسعينات؛ Block cipher بسيط وسريع؛ يستخدم مفتاح bit-80؛ كان مناسباً للأنظمة المضمنة من ناحية الذاكرة والكفاءة.
OCB / Offset Codebook Mode /	نمط تشغيل Block cipher المختار لـ MiniSec.
AES / معيار التشفير المتقدم	السللايد الأخير يذكر أن Skipjack لم يعد آمناً بسبب مفتاح bit-80، وأن AES بمفاتيح bit-128 مفضل حالياً عندما تتوفر موارد أكثر.

خلاصة الحفظ السريعة: **IoT Security** صعب بسبب كثرة الأجهزة، ضعف الموارد، التعقيد، الانتشار، ومشاكل التحديث والعبث الفيزيائي. الحماية تعتمد على طبقات: تقييد الوصول، حماية البيانات، الكشف، الاستمرارية، الاستعادة، مقاومة العبث، وأمن البوابة.

(12) جدول مراجعة نهائي سريع / Final Cheat Table

السؤال المتوقع	الإجابة المختصرة جداً
ما مكونات جهاز IoT؟	Sensor, Actuator, Microcontroller, Non-volatile memory, Transceiver, Battery.
ما الفرق بين Edge/Fog/Core/Cloud؟	Edge: أجهزة IoT؛ Fog: تحويل/تهينة/تقليل البيانات؛ Core: ربط الشبكات؛ Cloud: تخزين ومعالجة ضخمة.
لماذا أمن IoT صعب؟	سطح هجوم واسع، موارد محدودة، تعقيد، معايير متفرقة، انتشار واسع، أمن فيزيائي، تكامل صعب، تكلفة منخفضة، نقص خبرة، تحديثات، برمجة غير آمنة، مسؤوليات غير واضحة.
ما دور Gateway؟	مصادقة، حماية بيانات، خصوصية، تحديث، صيانة، ربط الأجهزة بالتطبيقات وتأمين الاتصال.
ما Tamper resistance؟	حماية سلبية تجعل العبث الفيزيائي صعباً مثل حاويات فولاذية وأقفال ومسامير أمنية.
ما Tamper detection؟	كشف الوصول الفيزيائي غير المرغوب عبر switches, sensors, circuitry.
ما MiniSec؟	وحدة أمن مفتوحة المصدر في TinyOS، مصممة لأمان عالي مع طاقة وذاكرة قليلة.
لماذا Skipjack غير مفضل الآن؟	لأن مفتاحه bit-80 أصبح غير آمن بالمعايير الحديثة؛ AES 128-bit أفضل عند توفر الموارد.